

THIRD-PARTY RISK MANAGEMENT AND CYBER SUPPLY CHAIN SECURITY

Practical Manager and Junior Analyst Manual

What this manual does: Explains how to identify, assess, contract with, monitor, respond to, and safely exit suppliers. It combines governance, practical testing, current NIST guidance, open-source tools, reusable templates, and career preparation.

Alberto (Al) Leiva

First Edition • July 2026

Preface

Organizations depend on cloud platforms, software, payment processors, consultants, data providers, managed services, artificial intelligence, and many other outsiders. The organization may outsource the work, but it does not outsource the business impact. A supplier failure can expose data, interrupt operations, weaken products, or create legal and customer obligations.

This manual teaches a repeatable life-cycle method. It is not a legal opinion, a guarantee, or a universal certification program. Requirements vary by contract, law, regulator, sector, customer, system, and country. Use qualified legal, privacy, procurement, security, and audit professionals when decisions require them.

Current-information note: The manual reflects official material checked on July 14, 2026, including NIST SP 1326 (final July 8, 2026), NIST SP 800-18 Rev. 2 (final June 30, 2026), NIST SP 800-161 Rev. 1 Update 1, NIST SP 1305, and NIST CSF 2.0.

How to use this manual

- Managers: begin with Chapters 2–4, 8–13, 19, and 25.
- Junior analysts: study in order, then complete Chapters 26–29 and the fictional lab.
- Procurement and legal teams: focus on intake, due diligence, contracts, onboarding, monitoring, incidents, and exit.
- Technical teams: focus on cloud, software supply chain, AI, open-source tools, evidence testing, and incident coordination.
- Use the templates as starting points; tailor criteria and approvals to your organization.

Table of Contents

This is a native Word table of contents. In Microsoft Word, click inside it, choose Update Table, and select Update entire table. Word will rebuild the entries and page numbers after editing.

Preface.....	2
How to use this manual.....	2
Table of Contents	3
Chapter Guide	6
1. TPRM and Cyber Supply Chain Foundations.....	7
1.1 What good TPRM produces	7
1.2 Important limits	7
2. The Third-Party Life Cycle	8
3. Governance, Strategy, and Risk Appetite	9
3.1 Program documents.....	9
4. Inventory, Classification, and Tiering	10
4.1 Inventory fields.....	10
4.2 Tiering factors	10
5. Intake and Inherent Risk.....	11
6. Due Diligence and Research	12
6.1 NIST SP 1326 assessment components.....	12
6.2 Research sources	12
7. Evidence Review and Trust.....	14
8. Risk Scoring and Treatment.....	15
8.1 A defensible method	15
9. Contract Requirements	16
10. Secure Onboarding.....	17
10.1 Acceptance evidence	17
11. Continuous Monitoring	18
11.1 Frequency.....	18
12. Findings, Remediation, and Exceptions.....	19
12.1 Exception discipline	19
13. Supplier Incidents and Notification.....	20
13.1 Prepare before an incident.....	20
14. Fourth Parties, Concentration, and Systemic Risk	21

14.1 What to map	21
14.2 Treat concentration	21
15. Cloud and SaaS Vendors	23
16. Software and Open-Source Supply Chains.....	24
16.1 Supplier and product checks	24
16.2 SBOM limits	24
17. Artificial Intelligence Vendors	25
18. Privacy and Data Protection	26
19. Resilience, Continuity, and Exit	27
19.1 Exit test.....	27
20. NIST CSF 2.0 Supplier Outcomes.....	28
21. NIST C-SCRM Guidance in Practice	29
21.1 Three-level thinking	29
22. Compliance and Framework Mappings	30
23. Evidence Testing and Metrics	31
23.1 Test method	31
24. Open-Source Tools	33
24.1 CISO Assistant	33
24.2 Dependency-Track	33
24.3 CycloneDX	34
24.4 Syft	34
24.5 Grype.....	34
24.6 Trivy	34
24.7 OpenSSF Scorecard	34
24.8 GUAC	35
24.9 OSV-Scanner	35
24.10 DefectDojo.....	35
24.11 Wazuh	35
24.12 Keycloak	35
24.13 OWASP ZAP	36
24.14 Greenbone Community Edition	36
24.15 Nmap.....	36
24.16 Open Policy Agent	36
25. Manager's TPRM Playbook	37

25.1 Manager operating rhythm	37
26. Junior Analyst Career Guide	38
26.1 Common job titles	38
26.2 Typical junior work.....	38
27. Fictional Laboratory and Portfolio	40
28. Thirty-Day Learning Plan.....	41
29. Interview Preparation	42
29.1 What is TPRM?	42
29.2 TPRM versus C-SCRM?	42
29.3 Inherent versus residual risk?.....	42
29.4 How do you tier a supplier?	42
29.5 How do you review a SOC 2 report?	42
29.6 Questionnaire limitation?	42
29.7 What is an SBOM?	42
29.8 How do you close a finding?	42
29.9 What if a critical supplier refuses evidence?	42
29.10 What makes a good junior analyst?	43
29.11 Questions to ask the employer	43
30. Templates, Glossary, Index, and References	44
30.1 Supplier inventory record.....	44
30.2 Due-diligence workpaper	44
30.3 Assurance review	44
30.4 Finding and exception record	44
30.5 Contract and exit checklist	45
30.6 Glossary	45
30.7 Subject index	45
30.8 Official references.....	46

Chapter Guide

1. TPRM and Cyber Supply Chain Foundations

Third-party risk management (TPRM) controls risks posed by external organizations, products, people, and services.

A third party may host systems, process data, supply software, provide staff, run critical operations, or support customers. Cyber supply-chain risk management (C-SCRM) is broader: it considers how technology is designed, developed, manufactured, integrated, delivered, operated, maintained, and retired across many tiers.

1.1 What good TPRM produces

- A complete, owned supplier inventory.
- Risk-based assessment before commitment.
- Security, privacy, resilience, audit, and incident terms in agreements.
- Controlled access and data handling during service.
- Monitoring that detects material changes and overdue risks.
- Practiced incident coordination and an executable exit plan.

1.2 Important limits

Item	What it does not prove
Questionnaire	A supplier assertion is not independent proof.
SOC 2 report	It covers stated systems, criteria, period, testing, and limitations—not every risk.
ISO certificate	It applies only to the certified scope and current certificate details.
Security rating	External signals can be useful but may be incomplete, stale, or misattributed.
Contract	A promise does not show that a control operates.
Tool result	Automation supports testing; it does not make the business decision.

Core principle: Outsource the activity, not accountability. The business owner remains responsible for understanding and managing the impact.

2. The Third-Party Life Cycle

A life-cycle process prevents assessment from becoming a one-time questionnaire.



Every supplier moves through one controlled life cycle

Figure 1. Third-party risk life cycle

Stage	Key decision	Minimum evidence
Intake	Is there a valid need and accountable owner?	Request, service description, owner, alternatives
Tier	How much harm could failure cause?	Data, access, dependency, availability, geography
Assess	Is residual risk acceptable?	Research, evidence, tests, findings, treatment
Contract	Are obligations enforceable?	Signed security/privacy/resilience terms
Onboard	Is access limited and approved?	Configuration, account, data-flow, acceptance records
Monitor	Has risk or performance changed?	Events, attestations, issues, metrics, reassessments
Exit	Are access, data, assets, and dependencies removed?	Revocation, deletion/return, transition, confirmation

3. Governance, Strategy, and Risk Appetite

Governance sets decision rights, risk boundaries, funding, and escalation.

3.1 Program documents

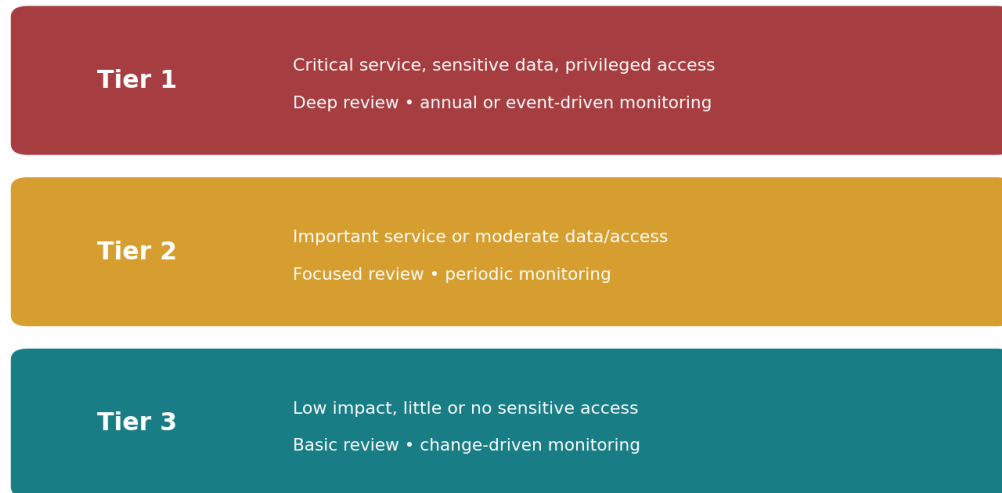
- TPRM/C-SCRM policy and standards.
- Risk appetite and mandatory rejection or escalation rules.
- Supplier classification and assessment method.
- Contract clause library and deviation approval.
- Monitoring, incident, exception, and exit procedures.
- Metrics, reporting, record retention, quality review, and program improvement.

Role	Accountability
Board/executive	Oversight, risk direction, resources, material-risk challenge
Business owner	Need, criticality, performance, residual-risk ownership, exit readiness
Procurement	Sourcing workflow, commercial terms, renewal, supplier record
Legal / privacy	Contract, legal basis, regulatory, data-transfer, notification advice
Security / TPRM	Method, due diligence, technical analysis, monitoring, findings
IT/engineering	Architecture, configuration, access, integration, testing, recovery
Internal audit	Independent evaluation of program design and operation
Supplier	Accurate information, contracted controls, notice, correction, cooperation

Manager decision: Define who may accept which level of residual risk. A risk owner must have authority, context, and accountability—not merely a convenient signature.

4. Inventory, Classification, and Tiering

Know every supplier and scale work to likely harm.



Tiering changes the depth and frequency of work—not whether risk is managed

Figure 2. Example supplier tiers

4.1 Inventory fields

- Legal name, aliases, product/service, business owner, technical owner, and contract owner.
- Purpose, systems, integrations, accounts, privileges, data categories, data locations, and transfer paths.
- Critical processes, recovery needs, replacement difficulty, fourth parties, concentration, and geographic exposure.
- Tier, inherent risk, residual risk, assessment status, findings, exceptions, contract dates, renewal, and exit status.

4.2 Tiering factors

Factor	Example high-risk condition
Data	Sensitive personal, health, payment, secrets, or regulated information
Access	Privileged, production, remote, persistent, or broad API access
Availability	Failure stops a critical product, operation, or customer service
Change	Supplier can update code, firmware, models, rules, or infrastructure
Dependency	Few substitutes, difficult migration, proprietary format, long recovery
Reach	Supplier serves many critical systems, regions, customers, or subsidiaries
Downstream	Material subprocessor, cloud, identity, model, or software dependency

5. Intake and Inherent Risk

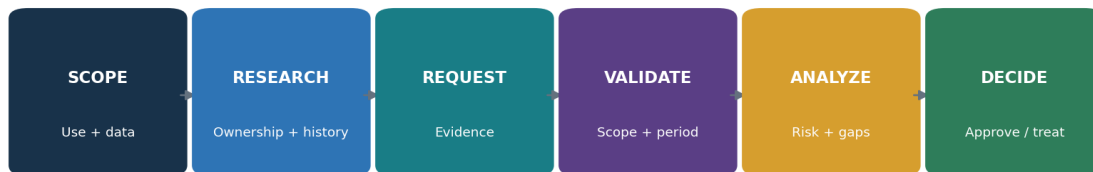
Intake captures the complete proposed use before commercial pressure makes review difficult.

1. Describe the business purpose and why an external supplier is needed.
2. Name accountable business, technical, privacy, security, procurement, and contract contacts.
3. Map data collected, created, accessed, stored, transmitted, trained on, returned, and deleted.
4. Describe connections, privileges, users, locations, fourth parties, and support access.
5. Determine criticality, recovery expectations, alternatives, and exit difficulty.
6. Identify laws, contracts, customer requirements, data residency, and sector obligations.
7. Calculate inherent risk before considering supplier controls.
8. Assign the required review path and stop unauthorized purchase or connection.

Inherent versus residual risk: Inherent risk is exposure before considering controls. Residual risk is what remains after verified controls, contract terms, design choices, and other treatment.

6. Due Diligence and Research

Due diligence gathers pertinent information so the organization can make an informed acquisition or continued-use decision.



Due diligence supports an informed decision before commitment

Figure 3. Due-diligence workflow

6.1 NIST SP 1326 assessment components

Component	Questions to investigate
Foreign ownership, control, or influence	Who owns or influences the supplier? What jurisdictions or legal pressures matter?
Provenance	Where did the product, code, components, hardware, and data originate? Can claims be traced?
Resilience	Can the supplier withstand, respond to, and recover from disruption?
Foundational cyber practices	Are basic governance, access, vulnerability, logging, development, response, and recovery practices present?
Supply-chain tiers	Which upstream and downstream organizations materially affect the product or service?

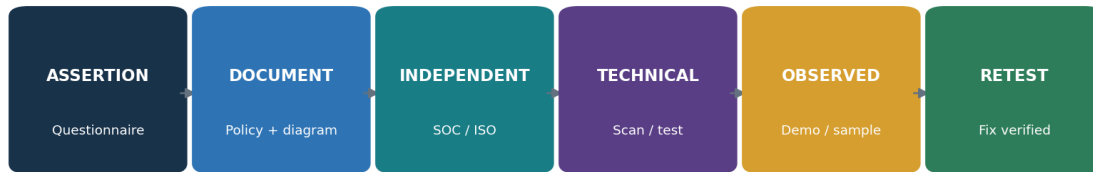
6.2 Research sources

- ✓ Supplier-provided organizational, technical, assurance, privacy, resilience, and product evidence.
- ✓ Official company, regulator, certification, court, sanctions, breach, vulnerability, and product-security sources were lawful and relevant.
- ✓ Independent audit or assessment reports and customer-managed technical tests.
- ✓ Architecture and data-flow interviews with people who operate the service—not only sales staff.

Fairness and accuracy: Verify identity, date, relevance, jurisdiction, and source quality. Give the supplier a reasonable opportunity to correct material factual errors. Follow law and policy for screening and personal information.

7. Evidence Review and Trust

Evidence is useful only when it matches the service, period, control, and risk being evaluated.



Confidence rises when evidence is relevant, reliable, current, and independently tested

Figure 4. Evidence confidence ladder

Artifact	Review points	Common trap
SOC 2 Type 2	Entity/system scope, criteria, period, opinion, tests, exceptions, CUECs, subservice organizations, subsequent events	Accepting the cover page or a report for another product
ISO/IEC 27001 certificate	Certified organization and locations, scope, ISO version, certificate body, accreditation, dates, status	Assuming certification covers every service and control
Penetration-test report	Tester independence/skill, scope, date, method, exclusions, severity, remediation, retest	Accepting an executive summary with unknown scope
Policy / standard	Approval, owner, version, scope, required action, exceptions	Treating written policy as operating proof
Questionnaire	Qualified respondent, precise answer, supporting evidence, unresolved gaps	Scoring every yes answer as verified
Architecture / data flow	Systems, trust boundaries, integrations, locations, encryption, administrators, fourth parties	Using an old sales diagram
BC/DR test	Scenario, scope, recovery objectives, observed results, failures, correction, retest	Accepting a plan without a test
Vulnerability evidence	Asset coverage, credentials, date, severity, remediation, exceptions, rescan	Counting scan output as risk treatment

8. Risk Scoring and Treatment

Risk scoring supports consistent decisions, but numbers must not hide uncertainty or severe single issues.

8.1 A defensible method

- ✓ Define likelihood and impact scales in plain language.
- ✓ Score by scenario: threat or failure, affected asset/process, weakness, and consequence.
- ✓ Separate inherent risk from control effectiveness and residual risk.
- ✓ Record evidence quality, uncertainty, assumptions, and missing information.
- ✓ Allow mandatory escalation for prohibited data use, privileged access, critical dependence, legal restrictions, or unresolved severe findings.
- ✓ Require approval at the correct authority level and record review/expiry.

Treatment	Example	Required record
Avoid	Choose another product or keep the activity internal	Decision and rationale
Reduce	Limit data, remove admin access, add MFA, fix vulnerabilities	Control, owner, date, test
Transfer/share	Insurance, indemnity, service credits, contractual allocation	Exact term and remaining risk
Accept	Authorized owner accepts defined residual risk for a period	Scope, reason, approver, expiry, monitoring
Contingency	Backup supplier, manual process, data export, tested recovery	Trigger, resources, test result

Scoring warning: Do not average away a catastrophic issue. Report severe scenarios, evidence gaps, and concentration separately from the overall score.

9. Contract Requirements

Contracts convert selected requirements into enforceable responsibilities.

Clause area	Questions for the agreement
Security program	Which framework, controls, policies, testing, training, and assurance evidence are required?
Data use	What data may be used, where, for what purpose, for how long, and for model training?
Access	How are least privilege, MFA, logging, support access, and termination handled?
Vulnerability	What scanning, disclosure, patch, severity, remediation, and notice rules apply?
Incident	What event triggers notice, how quickly, through which channel, with what updates and cooperation?
Subprocessors	Is approval or notice required? Do equivalent duties flow down? Is a current list available?
Audit / evidence	What reports, certifications, records, testing rights, and remediation proof may be requested?
Resilience	What availability, recovery, backup, testing, crisis communication, and continuity duties apply?
Change	Which ownership, hosting, location, feature, AI model, or control changes require notice or approval?
Exit	How are access, data, keys, assets, logs, transition support, retention, and deletion handled?
Liability	How do limitations, indemnity, insurance, remedies, and regulatory cooperation align with risk?

Legal review: Clause language and enforceability depend on law, jurisdiction, bargaining position, facts, and the entire agreement. Use qualified legal counsel.

10. Secure Onboarding

Onboarding turns promises into safe technical and operational settings.

- ✓ Confirm approval, signed terms, residual-risk decision, owners, and open preconditions.
- ✓ Verify architecture, data flow, environments, locations, subprocessors, and support model.
- ✓ Create named accounts; use SSO/MFA where appropriate; apply least privilege, approval, expiry, and logging.
- ✓ Secure API keys, secrets, certificates, agents, integrations, network paths, and administrative channels.
- ✓ Configure retention, deletion, sharing, training use, backups, export, alerts, and customer options.
- ✓ Test security, privacy, availability, support, incident contacts, and recovery/export requirements.
- ✓ Record the accepted configuration baseline and add the supplier to monitoring, incident, renewal, and exit schedules.

10.1 Acceptance evidence

- ✓ Approved onboarding checklist and unresolved exceptions.
- ✓ Access list, roles, MFA/SSO, privileged path, expiry, and test results.
- ✓ Production data-flow and architecture record.
- ✓ Configuration export or screenshots with date, reviewer, and sensitive values protected.
- ✓ Monitoring, incident contact, backup/export, and exit readiness test.

11. Continuous Monitoring

Monitoring detects meaningful changes and verifies that treatment continues to work.

Signal	Possible action
New critical vulnerability or exploitation	Confirm affected product/version, exposure, mitigation, patch, and retest
Incident, outage, or control failure	Invoke notification and coordination process; reassess risk
SOC/ISO/pen-test change	Review scope, exceptions, opinion/status, correction, and applicability
New subprocessor, owner, location, or model provider	Assess change, contract rights, data path, and concentration
Financial or operational distress	Review continuity, escrow/export, alternatives, and exit trigger
Repeated SLA or finding failure	Escalate corrective action and residual-risk decision
Renewal or material feature change	Reassess before commitment; update contract and architecture
No evidence or stale contact	Escalate according to tier and contract; do not silently mark complete

11.1 Frequency

1. Use tier- and trigger-based events, not a single universal annual schedule.
2. Critical suppliers may need continuous signals, regular service review, annual assurance, exercises, and event-driven reassessment.
3. Lower-tier suppliers still need ownership, control over contracts/renewals, incident routing, and change-driven review.

12. Findings, Remediation, and Exceptions

A finding is a documented gap between criteria and observed condition.

Finding element	Content
Criteria	Exact requirement, contract term, policy, or approved standard
Condition	What evidence showed, including affected population and date
Risk	Credible scenario and business impact
Cause	Why the gap occurred; avoid unsupported guesses
Action	Specific correction or compensating control
Owner / due date	Accountable person and risk-based deadline
Interim protection	Short-term measure while full correction is pending
Retest	Method, evidence, result, reviewer, and closure date

12.1 Exception discipline

Define scope, reason, affected assets/data/processes, risk, and alternatives.

Require authorized acceptance and an expiry date.

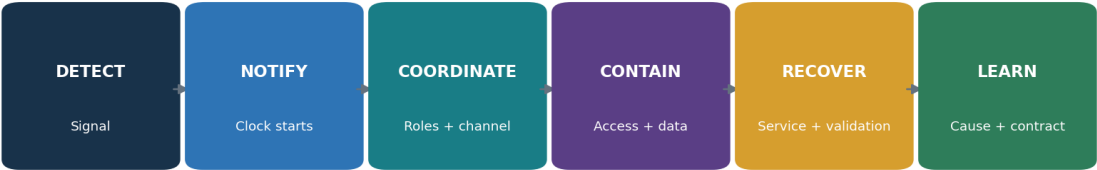
Add conditions, compensating controls, monitoring, and triggers for earlier review.

Track renewal separately from remediation; an exception is not permanent compliance.

Close only when evidence proves correction or the affected relationship ends.

13. Supplier Incidents and Notification

Supplier incidents require shared facts, roles, clocks, channels, and recovery decisions.



Supplier incident readiness depends on practiced contacts, facts, and decision rights

Figure 5. Supplier incident coordination

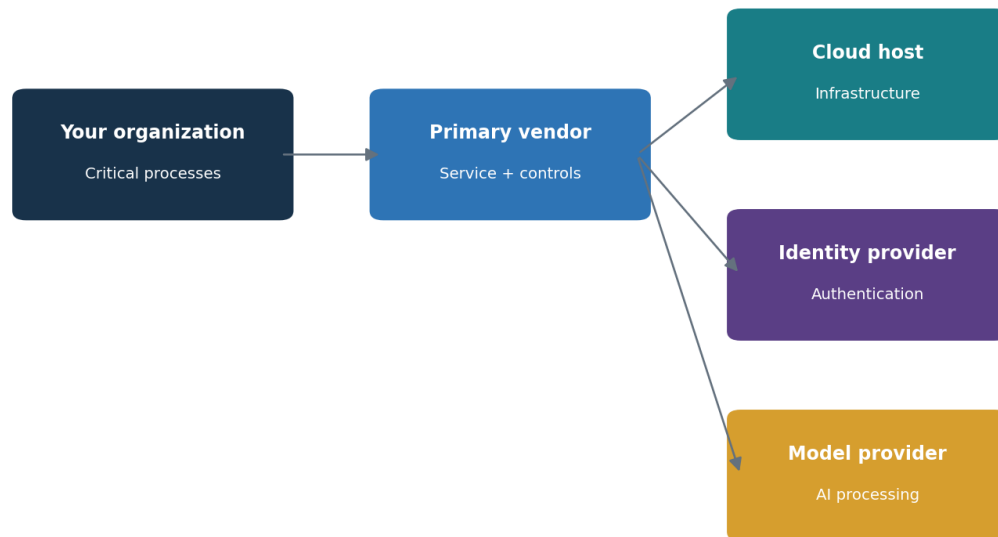
13.1 Prepare before an incident

- 1. Define reportable events and notification time, method, recipients, required facts, update frequency, and escalation.
- 2. Map supplier access, data, integrations, assets, fourth parties, and business dependencies.
- 3. Preapprove safe communication channels and alternate contacts.
- 4. Clarify evidence preservation, forensic access, regulator/customer support, public statements, containment, recovery, and cost responsibilities.
- 5. Exercise realistic supplier outage, breach, software compromise, identity compromise, and data-deletion scenarios.

First questions	Why they matter
What happened and when?	Establish timeline and notification obligations
Which product, tenant, region, version, accounts, data, and subprocessors?	Determine scope
Is the event contained? What remains active?	Guide protection decisions
What evidence supports the current conclusion?	Separate fact from assumption
What customer actions are required?	Coordinate keys, access, patches, configurations, and communication
When is the next update?	Maintain a reliable operating rhythm

14. Fourth Parties, Concentration, and Systemic Risk

Fourth-party and concentration risk can turn many separate supplier records into one shared failure.



One supplier can concentrate several hidden fourth-party dependencies

Figure 6. Hidden fourth-party concentration

14.1 What to map

- Cloud regions, identity services, DNS/CDN, payment rails, telecommunications, certificate authorities, code repositories, package registries, model providers, data providers, and managed operations.
- Common owners, geographies, facilities, technologies, software components, and support channels.
- Supplier dependencies that cannot be replaced within required recovery time.
- Contractual visibility, flow-down controls, incident notice, evidence rights, and exit support for material fourth parties.

14.2 Treat concentration

- Use diverse architecture only when it reduces correlated failure and can be operated safely.
- Build tested manual workarounds, data exports, alternate identity/recovery paths, and replacement plans.
- Set exposure limits and executive escalation for unavoidable concentration.

- Exercise simultaneous disruption across multiple suppliers.

15. Cloud and SaaS Vendors

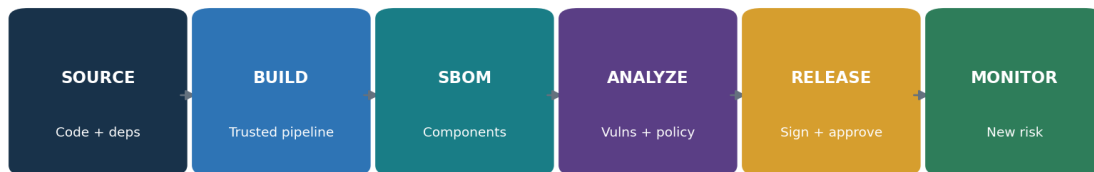
Cloud and SaaS risk depends on the shared-responsibility model and the organization's configuration.

Area	Verify
Tenant security	SSO, MFA, roles, admin accounts, sessions, support access, logging
Data	Categories, tenancy, encryption, keys, regions, replicas, backups, retention, deletion
Integration	APIs, tokens, webhooks, agents, networks, secrets, scopes, rate limits
Assurance	Exact cloud service and locations within report/certificate scope
Operations	Vulnerability, change, monitoring, incident, capacity, availability, recovery
Customer duties	Configuration, identities, endpoints, data classification, logs, backups, response
Exit	Export format, completeness, timing, cost, dependencies, secure deletion, continuity

Shared responsibility: A secure provider does not automatically create a secure tenant. Test the customer's configuration, access, integrations, data choices, and monitoring.

16. Software and Open-Source Supply Chains

Software risk includes supplier practices and every component, build step, update channel, and dependency.



Software supply-chain evidence must stay connected to the exact build and release

Figure 7. Software supply-chain evidence flow

16.1 Supplier and product checks

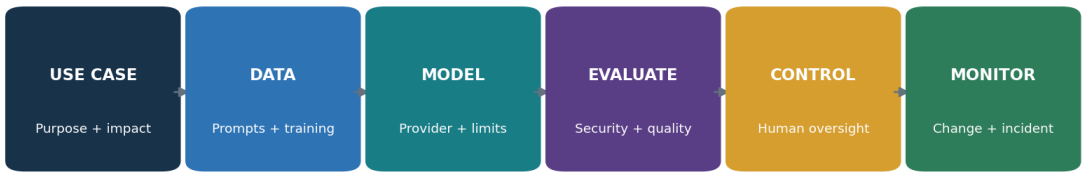
- ✓ Secure development governance, threat modeling, code review, testing, build isolation, secrets, access, provenance, signing, release approval, and change control.
- ✓ Vulnerability disclosure channel, coordinated disclosure, severity method, patch targets, supported versions, end-of-life notice, and customer advisories.
- ✓ SBOM format, version, completeness, direct/transitive components, licenses, hashes, and relationship to the shipped artifact.
- ✓ Update authenticity, rollback, telemetry, remote administration, default settings, and safe failure.
- ✓ Open-source maintenance, contributor trust, ownership transfer, release process, dependency pinning, and abandoned-component plan.

16.2 SBOM limits

- An SBOM is an inventory, not proof that software is safe.
- A vulnerability match requires applicability and exposure analysis.
- An SBOM may omit runtime, service, firmware, build, or dynamically loaded dependencies.
- Protect SBOMs when they reveal sensitive architecture; keep them current for every material release.

17. Artificial Intelligence Vendors

AI suppliers add changing models, training and prompt data, uncertain outputs, and hidden provider chains.



AI vendor risk includes data, models, people, downstream providers, and changing behavior

Figure 8. AI vendor risk workflow

Area	Questions
Use case / impact	What decision or task is supported? Who can be harmed? Is human review meaningful?
Data	Are prompts, uploads, outputs, feedback, and logs retained, shared, or used for training?
Model chain	Which model, hosting, plugins, agents, data sources, and subprocessors are involved?
Security	How are tenant isolation, access, secrets, tool permissions, prompt injection, abuse, and monitoring handled?
Privacy / IP	What legal basis, ownership, licensing, deletion, location, transfer, and rights apply?
Quality	How are accuracy, bias, robustness, explainability, drift, and unsafe output evaluated for this use?
Change	What model, policy, feature, provider, or training changes trigger notice and reevaluation?
Incident	How are harmful output, leakage, model compromise, abuse, outage, and evidence handled?
Exit	Can prompts, files, indexes, fine-tunes, logs, and derived data be exported or deleted?

18. Privacy and Data Protection

Privacy review follows the data through the entire supplier chain.

- Identify people, data categories, sensitivity, source, purpose, legal basis, and prohibited uses.
- Minimize fields, records, users, locations, retention, and access before transfer.
- Map controller/processor or equivalent roles and every material subprocessor.
- Evaluate notices, consent or other lawful basis, individual rights, government requests, and cross-border transfer requirements.
- Require security, confidentiality, breach cooperation, audit/evidence, return/deletion, and flow-down terms.
- Test access, export, correction, deletion, retention, backup behavior, and tenant configuration.
- Reassess when purpose, data, model training, location, subprocessor, ownership, or feature changes.

Data minimization: The safest sensitive data is often the data a supplier never receives. Reduce collection and access before relying on complicated controls.

19. Resilience, Continuity, and Exit

Resilience means delivering critical outcomes despite supplier disruption and leaving safely when necessary.

Capability	Evidence to test
Business impact	Critical service, maximum tolerable disruption, RTO/RPO, dependencies
Backup/recovery	Scope, isolation, restore test, observed time, data loss, failures, retest
Continuity	People, facilities, technology, communications, manual workarounds, exercises
Capacity/availability	Architecture, regions, limits, monitoring, incidents, SLA performance
Exit plan	Triggers, decision rights, alternative, data export, access removal, migration sequence
Deletion	Production, backup, logs, devices, derived data, AI artifacts, subprocessors, evidence
Post-termination	Retention, legal hold, confidentiality, vulnerability/incident notice, support

19.1 Exit test

- Export a representative data set and confirm completeness, format, metadata, permissions, and usable restoration.
- Inventory every supplier account, key, certificate, agent, route, device, license, integration, and data copy.
- Estimate migration time and business interruption from observed tests—not sales claims.
- Document who confirms return/deletion and how exceptions such as legal hold or backup retention are controlled.

20. NIST CSF 2.0 Supplier Outcomes

NIST CSF 2.0 places supply-chain governance in the GV.SC Category.

Outcome	Plain meaning	Example evidence
GV.SC-01	A C-SCRM program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders.	Approved program and stakeholder record
GV.SC-02	Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated.	RACI, contacts, agreements, exercises
GV.SC-03	C-SCRM is integrated into enterprise risk management, cybersecurity risk assessment, and improvement processes.	ERM linkage, risk register, lessons and improvements
GV.SC-04	Suppliers are known and prioritized by criticality.	Complete supplier inventory and criticality method
GV.SC-05	Supply-chain cybersecurity requirements are established, prioritized, and included in contracts and agreements.	Requirements library, signed terms, deviations
GV.SC-06	Planning and due diligence are performed before entering formal supplier relationships.	Intake, research, evidence, analysis, approval
GV.SC-07	Supplier risks are understood, recorded, prioritized, assessed, treated, and monitored throughout the relationship.	Risk records, monitoring, findings, treatment
GV.SC-08	Relevant suppliers are included in incident planning, response, and recovery.	Plans, contacts, tabletops, incident records
GV.SC-09	Supply-chain security practices are integrated and monitored throughout the technology product and service life cycle.	Lifecycle requirements, product/service evidence
GV.SC-10	Cybersecurity supply chain plans include activities that occur after a partnership or service agreement ends.	Exit plan, access/data removal, post-termination duties

Using GV.SC: Define a Current Profile from observed outcomes and a Target Profile from business needs. Prioritize gaps, owners, resources, and dates; do not treat a mapping as automatic implementation.

21. NIST C-SCRM Guidance in Practice

Current NIST publications provide complementary guidance on program, assessment, and planning.

Publication	Current role
NIST SP 800-161 Rev. 1 Update 1	Integrates C-SCRM into organization-wide risk management at enterprise, mission/business, and system levels; includes strategy, policy, plans, assessments, and controls.
NIST SP 1305	Uses NIST CSF 2.0 GV.SC to establish and operate C-SCRM and communicate supplier requirements.
NIST SP 1326 (final July 8, 2026)	Quick-start considerations for ICT supplier due diligence assessments: FOCL, provenance, resilience, foundational cyber practices, and supply chain tiers.
NIST SP 800-18 Rev. 2 (final June 30, 2026)	Defines essential elements for system security, privacy, and C-SCRM plans, including purpose, control status, responsibilities, and expected behavior.

21.1 Three-level thinking

Level	Focus	Example
Enterprise	Strategy, risk appetite, common policy, resources, oversight	Supplier concentration limits and program metrics
Mission / business process	Critical services and dependencies	Payment operations or patient scheduling
System	Specific product, service, architecture, controls, and plan	Customer platform using a cloud and identity provider

Plan versus proof: A C-SCRM plan explains intended and implemented arrangements. Assessors still need reliable evidence that the relevant controls operate.

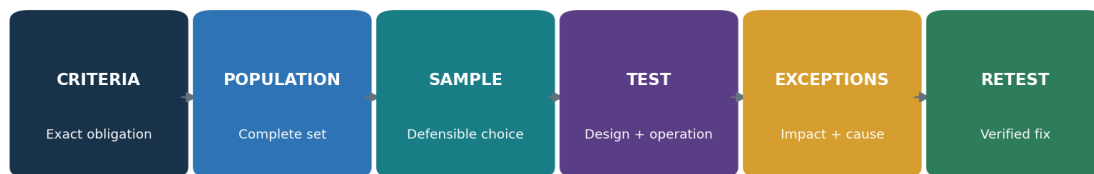
22. Compliance and Framework Mappings

Mappings coordinate work, but each obligation must be interpreted and tested on its own terms.

Framework / obligation	Supplier-risk connection	Caution
SOC 2	Vendor management, risks, commitments, system boundaries, subservice organizations, CUECs	Review exact report scope, period, criteria, opinion, tests, exceptions
ISO/IEC 27001:2022	Interested parties, supplier relationships, ICT supply chain, cloud use, monitoring and change	Certification scope and control applicability vary
PCI DSS v4.0.1	Third-party service providers, responsibilities, agreements, monitoring, incident support	Validate the entity's own scope and responsibilities
HIPAA	Business associates, agreements, safeguards, incidents, subcontractors	Legal status and duties depend on facts and law
GDPR	Processors, contracts, subprocessors, security, transfers, assistance, deletion/audit	Roles, jurisdiction, lawful basis, and transfer mechanism require legal analysis
CIS Controls v8.1	Control 15 service-provider inventory, policy, classification, contracts, assessment, monitoring, decommissioning	Safeguards are a prioritized baseline, not universal legal compliance
NIST CSF 2.0	GV.SC plus organization-wide Govern, Identify, Protect, Detect, Respond, Recover outcomes	Profiles are tailored; CSF is not a certification

23. Evidence Testing and Metrics

Testing asks whether controls are properly designed, implemented, and operating for the complete scope.



A conclusion is only as strong as its criteria, population, evidence, and method

Figure 9. Evidence-testing chain

23.1 Test method

Define exact criteria, objective, period, systems, suppliers, data, locations, and exclusions. Identify the complete population and validate its completeness and accuracy using independent sources where possible.

Choose full-population testing or a defensible sample; record selection and limitations.

Inspect, observe, inquire, and reperformance as appropriate. Inquiry alone is usually weak.

Record evidence source, date, owner, version, reviewer, and protected location.

Describe exceptions precisely and evaluate frequency, severity, pattern, impact, cause, and compensating controls.

Track correction and perform an independent retest before closure.

Metric	Example calculation	What it can reveal
Inventory ownership	Suppliers with valid owner ÷ active suppliers	Orphaned relationships
Assessment coverage	In-scope suppliers with current completed assessment ÷ in-scope suppliers	Program backlog
Contract coverage	High-tier suppliers with required clauses ÷ high-tier suppliers	Unenforceable expectations
Critical finding age	Days from finding date to closure or today	Remediation delay
Incident notice performance	Events notified within contracted time ÷ reportable events	Coordination reliability
Exit readiness	Critical suppliers with tested export/exit plan ÷ critical suppliers	Lock-in and recovery exposure
Concentration	Critical services dependent on same provider/region/technology	Correlated failure

Metric quality: Always show numerator, denominator, as-of date, inclusion rules, data owner, limitations, trend, and action. A green percentage can hide one severe exception.

24. Open-Source Tools

Open-source tools can support inventory, evidence, software assurance, technical testing, monitoring, and remediation.

Tool	Purpose
CISO Assistant	Risk, controls, assessments, evidence, and findings
Dependency-Track	SBOM analysis and component-risk monitoring
CycloneDX	Software bill of materials standard and tools
Syft	SBOM generation for images and filesystems
Grype	Vulnerability scanning for images and SBOMs
Trivy	Repository, image, dependency, secret, and IaC checks
OpenSSF Scorecard	Signals about open-source project security practices
GUAC	Graphing software supply-chain metadata
OSV-Scanner	Known-vulnerability checks for dependencies
DefectDojo	Finding intake, deduplication, remediation, and retest
Wazuh	Endpoint monitoring, file integrity, log analysis, and alerts
Keycloak	Identity, roles, MFA, sessions, and events
OWASP ZAP	Authorized web application testing
Greenbone Community Edition	Authorized vulnerability assessment
Nmap	Authorized service and asset discovery
Open Policy Agent	Policy-as-code decisions

Authorization and limits: Use tools only on systems, repositories, networks, data, and accounts you own or have written permission to test. Protect results. A tool supports evidence; it does not certify a supplier or replace legal, business, and human judgment.

24.1 CISO Assistant

Purpose: Risk, controls, assessments, evidence, and findings. Official project: [CISO Assistant](#)

Safe quick start: Create a scoped project, define risk criteria, assign owners, attach reviewed evidence, record findings, and restrict access.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.2 Dependency-Track

Purpose: SBOM analysis and component-risk monitoring. Official project: [Dependency-Track](#)

Safe quick start: Import a CycloneDX SBOM from a lab project, confirm components, review vulnerability and policy alerts, assign action, and import a fresh SBOM after correction.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.3 CycloneDX

Purpose: Software bill of materials standard and tools. Official project: [CycloneDX](#)

Safe quick start: Use an official generator for the project language, create an SBOM, validate it, protect sensitive metadata, and provide it to approved analysis tools.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.4 Syft

Purpose: SBOM generation for images and filesystems. Official project: [Syft](#)

Safe quick start: Run against an authorized lab image, export CycloneDX JSON, review package coverage, record the version and command, and store the result safely.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.5 Gripe

Purpose: Vulnerability scanning for images and SBOMs. Official project: [Gripe](#)

Safe quick start: Scan the lab image or its SBOM, validate important results, identify fixed versions, remediate, and rescan.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.6 Trivy

Purpose: Repository, image, dependency, secret, and IaC checks. Official project: [Trivy](#)

Safe quick start: Scan only approved repositories or images, review scope and false positives, correct findings, document exceptions, and rescan in CI.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.7 OpenSSF Scorecard

Purpose: Signals about open-source project security practices. Official project: [OpenSSF Scorecard](#)

Safe quick start: Review a public project or an authorized repository, understand each check, verify important signals manually, and do not treat the score as proof of safety.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.8 GUAC

Purpose: Graphing software supply-chain metadata. Official project: [GUAC](#)

Safe quick start: Load the approved SBOM and vulnerability metadata in a lab, query component relationships, verify provenance, and protect the graph, as it may reveal the architecture.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.9 OSV-Scanner

Purpose: Known-vulnerability checks for dependencies. Official project: [OSV-Scanner](#)

Safe quick start: Scan an authorized lockfile, repository, image, or SBOM; validate applicability; upgrade or mitigate; and preserve before-and-after results.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.10 DefectDojo

Purpose: Finding intake, deduplication, remediation, and retest. Official project: [DefectDojo](#)

Safe quick start: Create a test engagement, import safe results, validate deduplication, assign owners and due dates, attach proof, and close only after retest.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.11 Wazuh

Purpose: Endpoint monitoring, file integrity, log analysis, and alerts. Official project: [Wazuh](#)

Safe quick start: Enroll a lab endpoint, produce a harmless test event, confirm collection and alerting, investigate, and retain coverage and response evidence.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.12 Keycloak

Purpose: Identity, roles, MFA, sessions, and events. Official project: [Keycloak](#)

Safe quick start: Create a lab realm, configure roles and MFA, test joiner-mover-leaver cases and vendor access expiry, then review events.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.13 OWASP ZAP

Purpose: Authorized web application testing. Official project: [OWASP ZAP](#)

Safe quick start: Use a training application, proxy traffic, crawl passively, use active scanning only with written approval, validate findings, fix, and retest.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.14 Greenbone Community Edition

Purpose: Authorized vulnerability assessment. Official project: [Greenbone Community Edition](#)

Safe quick start: Update feeds, define approved lab targets, use safe credentials, review coverage, validate findings, correct, and rescan.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.15 Nmap

Purpose: Authorized service and asset discovery. Official project: [Nmap](#)

Safe quick start: Scan only written-authorized ranges with limited options, compare results with inventory, investigate unknown services, and preserve scope and command evidence.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

24.16 Open Policy Agent

Purpose: Policy-as-code decisions. Official project: [Open Policy Agent](#)

Safe quick start: Write a small lab policy for an approved supplier attribute, test allow and deny cases, peer-review changes, log decisions, and keep human exception approval.

Evidence to retain: approval and scope, tool/version, configuration or command, date, target population, raw result, analyst validation, limitation, finding, action, and retest. Limit access because results may expose sensitive architecture or weaknesses.

25. Manager's TPRM Playbook

Managers make the program real by setting priorities, resolving conflict, funding treatment, and challenging evidence.

Dashboard area	Manager question	Escalate when
Inventory	Do we know every active supplier, owner, service, data path, and dependency?	Unknown critical service or orphaned owner
Assessment	Are high-risk decisions completed before commitment?	Purchase, access, or data transfer bypassed review
Evidence	Does assurance cover the exact service and period?	Material gap, exception, weak scope, or stale report
Contracts	Are material requirements signed and deviations approved?	Critical clause absent or unenforceable
Findings	Who owns severe and overdue issues?	Severe risk lacks interim protection or decision
Incidents	Can we contact and coordinate with critical suppliers now?	Contacts, clocks, or roles untested
Concentration	Where could one event disrupt several critical services?	Unavoidable concentration lacks contingency
Exit	Can we retrieve data and replace the service in time?	No tested export, alternative, or deletion path

25.1 Manager operating rhythm

Monthly: review critical changes, severe findings, incidents, bypasses, overdue work, and concentration.

Quarterly: challenge high-tier coverage, treatment progress, contract gaps, monitoring quality, and exit readiness.

At least annually: review strategy, appetite, tiering, methods, resources, major dependencies, exercises, metrics, and program improvement.

At renewal or material change: reassess before new commitment, not after signature.

Questions that matter: What can fail? Who is affected? What evidence supports the conclusion? What remains uncertain? Who must act by when? How will we know the fix worked?

26. Junior Analyst Career Guide

Junior analysts create value by producing accurate inventories, evidence reviews, findings, and follow-through.



Junior analysts build trust by doing careful, honest, repeatable work

Figure 10. Junior TPRM analyst pathway

26.1 Common job titles

Third-Party Risk Analyst
 Vendor Risk Analyst
 Cyber Supply Chain Analyst
 GRC Analyst
 Security Assurance Analyst
 IT Risk or Compliance Analyst
 Supplier Security Analyst
 Software Supply Chain Analyst

26.2 Typical junior work

Review intake forms and reconcile supplier inventories.
 Classify suppliers using approved criteria and escalate unclear high-risk facts.
 Request, track, and organize evidence without altering source records.
 Read SOC 2 reports, certificates, policies, diagrams, test summaries, and resilience evidence.
 Write criteria-condition-risk-action findings and track correction through retest.
 Maintain contract requirement, subprocessor, incident contact, reassessment, renewal, and exit records.
 Use authorized tools in labs or approved environments and explain limitations.

Prepare clear manager summaries without claiming certainty beyond the evidence.

Skill	Portfolio proof
Lifecycle	Supplier record from intake through exit
Evidence	Annotated SOC 2/ISO/pen-test review checklist using synthetic facts
Risk	Three scenario-based assessments with uncertainty
Technical literacy	SBOM and vulnerability analysis from a training project
Writing	Finding, manager summary, contract gap, and retest memo
Data	Dashboard with defined populations and calculations
Ethics	Written authorization, synthetic data, redaction, and honest limitations

27. Fictional Laboratory and Portfolio

Build a safe portfolio with a fictional company, synthetic suppliers, and isolated technical labs.

Lab rule: Never scan or test public targets, employers, suppliers, or accounts without written authorization. Use synthetic data and intentionally vulnerable training systems. Do not publish secrets or sensitive results.

9. Create a fictional 75-person company with customer data, cloud services, remote staff, a payment function, and an AI pilot.
10. Create ten fictional suppliers and a complete inventory with owners, data, access, dependencies, contract dates, and tiers.
11. Write intake and inherent-risk records for a cloud CRM, managed IT provider, payroll service, software library, and AI assistant.
12. Create synthetic SOC 2, ISO certificate, pen-test summary, policy, data flow, and recovery-test facts; document scope and gaps.
13. Write three due-diligence assessments using the five NIST SP 1326 components.
14. Build a risk register, treatment plans, exception, contract checklist, onboarding checklist, and monitoring calendar.
15. Generate an SBOM for an authorized training project with Syft or CycloneDX; analyze it with Gype, Trivy, OSV-Scanner, or Dependency-Track.
16. Create a fourth-party concentration map and a cloud shared-responsibility matrix.
17. Run a supplier breach tabletop and a supplier outage/exit exercise.
18. Publish sanitized workpapers, a dashboard, and a one-page manager report clearly labeled fictional and educational.

Artifact	What it demonstrates
Supplier inventory and tiering	Population management and prioritization
Due-diligence memo	Research, evidence quality, and reasoned decision
Assurance review	Scope, period, exceptions, CUECs, and limitations
Risk register / finding	Scenario, criteria, action, owner, and retest
Contract checklist	Translation of risk into enforceable requirements
SBOM lab	Software component and vulnerability literacy
Incident tabletop	Roles, facts, communication, and improvement
Exit test	Resilience, portability, revocation, and deletion
Manager dashboard	Clear metrics, severe issues, uncertainty, and action

28. Thirty-Day Learning Plan

A focused month can build useful entry-level capability.

Days	Focus	Deliverable
1–3	TPRM/C-SCRM terms, lifecycle, roles	Concept map and lifecycle record
4–6	Inventory, criticality, tiering, inherent risk	Ten-supplier inventory and tier memo
7–10	Due diligence and NIST SP 1326	Three research-based assessments
11–13	SOC 2, ISO, pen test, policy, diagrams	Evidence review workpapers
14–16	Risk, findings, treatment, exceptions	Risk register and two findings
17–19	Contracts, onboarding, monitoring	Clause and onboarding checklists
20–22	Incidents, resilience, exit	Tabletop and exit test
23–25	Cloud, software supply chain, AI	Three focused assessments
26–27	Open-source tool lab	SBOM, scan, correction, rescan
28–30	Metrics, portfolio, interview	Dashboard, manager memo, five STAR stories

29. Interview Preparation

Interview answers should be short, accurate, and tied to examples.

29.1 What is TPRM?

A life-cycle process for identifying, assessing, contracting for, monitoring, responding to, and exiting risks from outside organizations, products, people, and services.

29.2 TPRM versus C-SCRM?

TPRM manages outside relationships broadly. C-SCRM focuses on cybersecurity risk across the full technology supply chain and product or service life cycle.

29.3 Inherent versus residual risk?

Inherent risk exists before controls. Residual risk remains after verified controls and treatment.

29.4 How do you tier a supplier?

Use documented impact factors such as data, privilege, availability, change authority, substitutability, reach, geography, and downstream dependencies.

29.5 How do you review a SOC 2 report?

Check the exact entity and system, criteria, period, opinion, tests, exceptions, CUECs, subservice organizations, and subsequent events; then map it to the actual use.

29.6 Questionnaire limitation?

It is a supplier assertion. I validate important answers with relevant, current, reliable evidence and record gaps.

29.7 What is an SBOM?

A structured inventory of software components and relationships. It improves visibility but does not prove security or vulnerability applicability.

29.8 How do you close a finding?

Retest the corrected control using defined criteria and reliable evidence; do not close only because the supplier says it is fixed.

29.9 What if a critical supplier refuses evidence?

Record the gap, use available independent evidence, consider design and contract options, assess uncertainty and risk, and escalate to the authorized decision maker.

29.10 What makes a good junior analyst?

Careful scope, complete records, evidence skepticism, clear writing, respectful follow-up, secure handling, and honest conclusions.

29.11 Questions to ask the employer

Which suppliers and risks are most important to the program?

How are inventories reconciled with procurement, finance, identity, network, and application records?

What evidence and contract standards are used by tier?

How are severe findings, exceptions, incidents, and renewals escalated?

Which tools are approved, and how is analyst work reviewed?

What would success look like in the first 90 days?

30. Templates, Glossary, Index, and References

Reusable structures, key terms, a subject index, and official starting points.

30.1 Supplier inventory record

Field	Entry
Legal name / service	_____
Business and technical owners	_____
Purpose and critical processes	_____
Data / locations / transfers	_____
Access / integrations / privileges	_____
Fourth parties / concentration	_____
Tier / inherent / residual risk	_____
Contract / renewal / notice dates	_____
Assessment / findings / exceptions	_____
Monitoring / incident / exit status	_____

30.2 Due-diligence worksheet

Field	Entry
Decision and scope	_____
Sources / dates / reliability	_____
FOCI	_____
Provenance	_____
Resilience	_____
Foundational cyber practices	_____
Supply-chain tiers	_____
Evidence gaps / uncertainty	_____
Risk scenarios / treatment	_____
Conclusion / approver / expiry	_____

30.3 Assurance review

Field	Entry
Artifact / issuer / date	_____
Entity / system / location scope	_____
Criteria / standard / period	_____
Opinion or status	_____
Tests / exceptions / findings	_____
CUECs / customer duties	_____
Subservice organizations	_____
Subsequent events / changes	_____
Applicability to our use	_____
Gaps / action / retest	_____

30.4 Finding and exception record

Field	Entry
Criteria	_____

Field	Entry
Condition / population / evidence	_____
Risk scenario / impact	_____
Cause / uncertainty	_____
Action / interim protection	_____
Owner / due date	_____
Exception approver / expiry	_____
Monitoring / trigger	_____
Retest method / evidence	_____
Closure result / date	_____

30.5 Contract and exit checklist

Security, privacy, confidentiality, access, logging, vulnerability, development, data use, AI training, location, subprocessor, assurance, audit, incident, resilience, change, insurance/liability, termination, transition, return, deletion, and post-termination duties reviewed.

Every material deviation has a documented risk decision and owner.

Exit inventory covers data, accounts, keys, certificates, agents, routes, devices, integrations, subprocessors, backups, logs, AI artifacts, legal holds, and deletion proof.

30.6 Glossary

Term	Meaning
Attestation	A statement or report that provides assurance about specified subject matter.
C-SCRM	Cybersecurity supply chain risk management.
Concentration risk	Exposure created when several critical services depend on the same provider, place, technology, or resource.
CUEC	Complementary user entity control: a control the customer is expected to perform for report objectives to be achieved.
Due diligence	Investigative research of pertinent supplier or product information for an informed decision.
First party	The organization managing its own risk.
FOCI	Foreign ownership, control, or influence.
Fourth party	A supplier or dependency used by the organization's third party.
Inherent risk	Risk before considering controls or treatment.
Provenance	Traceable origin and history of a product, component, code, data, or process.
Residual risk	Risk remaining after treatment.
Risk appetite	Amount and type of risk an organization is willing to pursue or retain.
SBOM	Software bill of materials: a structured component inventory.
Subprocessor	A party engaged by a processor to process personal data.
Third party	An outside organization, product, service, or person that supports the organization.
TPRM	Third-party risk management across the relationship life cycle.

30.7 Subject index

Subject	Chapter
AI vendors	17
Cloud / SaaS	15
Concentration	14, 25
Contracts	9, 30
Due diligence	6, 21, 30
Evidence	7, 23
Exit	19, 30
Fourth parties	14

Subject	Chapter
Incidents	13
Inventory / tiering	4
Junior analyst	26–29
Metrics	23, 25
NIST CSF GV.SC	20
NIST SP 1326	6, 21
Open-source tools	24
Privacy	18
Risk scoring	8
SBOM / software	16, 24
SOC 2 / ISO evidence	7
Supplier monitoring	11

30.8 Official references

[NIST SP 1326 — Due Diligence Assessment Quick-Start Guide](#)

[NIST SP 800-18 Rev. 2 — System Security, Privacy, and C-SCRM Plans](#)

[NIST SP 800-161 Rev. 1 Update 1 — C-SCRM Practices](#)

[NIST SP 1305 — CSF 2.0 C-SCRM Quick-Start Guide](#)

[NIST Cybersecurity Framework 2.0](#)

[NIST C-SCRM Publications](#)

[CISA ICT Supply Chain Resource Library](#)

[CISA ICT SCRM Task Force](#)

[CISA Vendor SCRM Questionnaire Template](#)

[CISA ICT SCRM Resources for Small and Medium Businesses](#)

[OWASP Software Component Verification Standard](#)

[OpenSSF Best Practices](#)

Final reminder: Frameworks, guidance, laws, contracts, suppliers, threats, tools, products, and official interpretations change. Confirm the current official source and applicable obligations before a real decision or assessment.